

XORCISM — Decide · Act · Prove

Where does this platform help us decide, act, and prove what happened?

One platform runs the whole loop on a single data model — and the proof feeds the next decision. Most tools do one of these three; XORCISM does all three, continuously, and closes the loop.

① DECIDE — what actually matters, and what is it worth?

Exposure fusion score

Which few exposures move risk: EPSS · KEV · public exploits · CTI · blast radius · internet-facing.

[/exposure](#)

CTEM program

A continuous discover -> prioritize -> remediate exposure program.

[/ctem](#)

Attack paths & choke points

The routes to your crown jewels, and the one fix that breaks the most paths.

[attack-path](#) [graph](#)

Cyber Risk Quantification (\$)

Risk in currency — FAIR / FAIR-MAM, one Enterprise Risk Score.

[risk register](#) / [CRQ](#)

Structured risk & threat-informed

Rigorous, navigable risk decisions, prioritized by adversary behaviour.

[EBIOS RM](#) / [NIST 800-30](#) / [SSVC](#)
[/ TID](#)

② ACT — do something about it, safely and fast

Autonomous Exposure Remediation

Owner-routed, SLA-bound plans: plan -> gate -> execute -> verify -> close.

[/exposure-remediation](#)

Agent Policy Firewall

Gates every automated/agent action first: blast radius · policy · replay · segregation-of-duties.

[/agent-firewall](#)

CROC Continuous Defense Loop

Fires the real fixes through your stack — ITSM · IAM · SOAR · Teams — dry-run safe.

[/croc](#)

Patch, SOC IR & crisis

Remediation at scale, IR playbooks (MTTD/MTTA/MTTR), tabletops, purple-team validation.

[/patch-management](#) / [/soc](#)

③ PROVE — show exactly what happened

Control Assurance

Controls passing live from telemetry — not a screenshot from last quarter.

[/assurance](#)

Audit package (OSCAL / SARIF)

Machine-readable evidence: AI-narrated report + OSCAL SSP + POA&M + SARIF.

[/api/audit-package](#)

Tamper-evident audit ledger

A SHA-256 hash chain over the audit log; integrity verifiable on demand.

[/api/admin/audit/verify](#)

Signed-receipt chains

Every autonomous remediation and agent action cryptographically sealed.

[AER](#) / [Agent Policy Firewall](#)

Trust Center & 48 frameworks

A live, public security posture; DFIR chain of custody with acquisition hashes.

[/trust-center](#)

The loop: Decide -> Act -> Prove -> (the proof feeds the next Decide). Maps to NIST CSF 2.0 (Identify -> Protect/Respond -> Govern/evidence) and Gartner CTEM (Prioritization/Validation -> Mobilization -> continuous monitoring).

RFP-style answers

Q: Does it prioritize by real risk, not just CVSS?

Yes — the exposure fusion score combines EPSS, CISA KEV, exploit availability, threat intel, asset value, internet-facing reachability and attack-path blast radius into one priority, quantified in currency (FAIR / FAIR-MAM).

Q: Can it automate remediation with human oversight?

Yes — an autonomy ladder (manual -> assisted -> supervised -> autonomous) and the Agent Policy Firewall gate every action; low-risk fixes auto-run, high-impact ones require approval. Execution flows through ITSM/IAM/SOAR and is dry-run safe.

Q: How do you verify a remediation actually worked?

Closed-loop verification re-checks the live exposure state; a plan closes only when the exposure is gone, and reopens/escalates if it persists past SLA.

Q: How is audit evidence produced?

Control Assurance derives pass/fail from live telemetry; the audit package exports OSCAL (SSP + POA&M) and SARIF; the audit log is a tamper-evident SHA-256 chain; automated actions carry signed receipts; the Trust Center publishes a live posture.

Q: Where does our data go?

Nowhere. XORCISM is free, open-source and self-hosted, with local-first AI (Ollama). No outbound telemetry.

XORCISM — free & open-source · self-hosted · local-first AI · <https://xorcism.ai>